HOCHSCHULE MAINZ
Wirtschaft
Business

Organisatorische Resilienz II: Rollen und Verantwortlichkeiten

Cyber Security Management · Termin 6

Prof. Dr. Dirk Loomans

University of
Applied Sciences

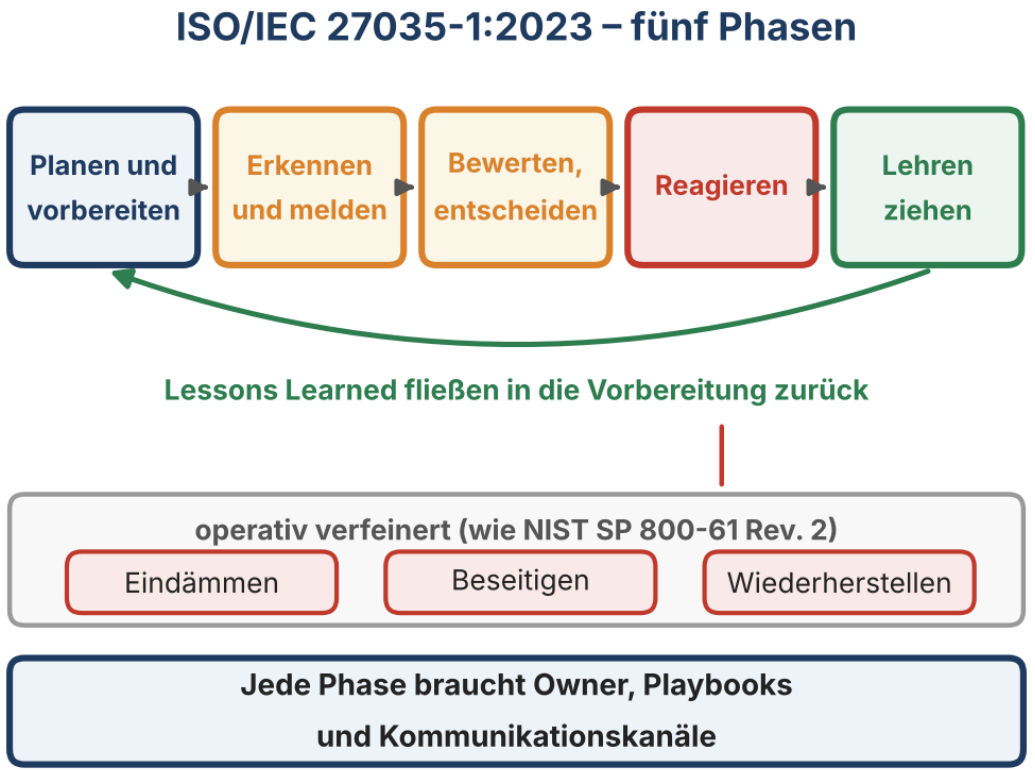
Agenda

- Rückblick & Lernziele
- Einstieg: Target 2013 – der Alarm kam an
- Vom Individuum zur Organisation
- CISO: Mandat und Haftung (Uber, SolarWinds)
- SOC und CERT · externe Rollen (Uniklinik Düsseldorf)
- Weitere Schlüsselrollen · Rollenaufbau (Hochschule Kaiserslautern)
- Eskalation, Meldepflichten, Management (MGM und Caesars)
- Konflikte, Governance-Matrix, Standards
- Übung · Kernpunkte & Ausblick

Rückblick Sitzung 5

- Organisationale Resilienz: **Technik schafft Potenzial, Organisation aktiviert es**
- **Rollen statt Personen**, Entscheidungskompetenz auf Zeit (Anhalt-Bitterfeld)
- Incident-Management nach ISO/IEC 27035-1 – **jede Phase braucht einen Owner**
- Übung und Lernen ohne Schuldzuweisung (LÜKEX 23, Cloudflare)

Heute: Welche Rollen sind das konkret – und wo reiben sie sich?



Lernziele

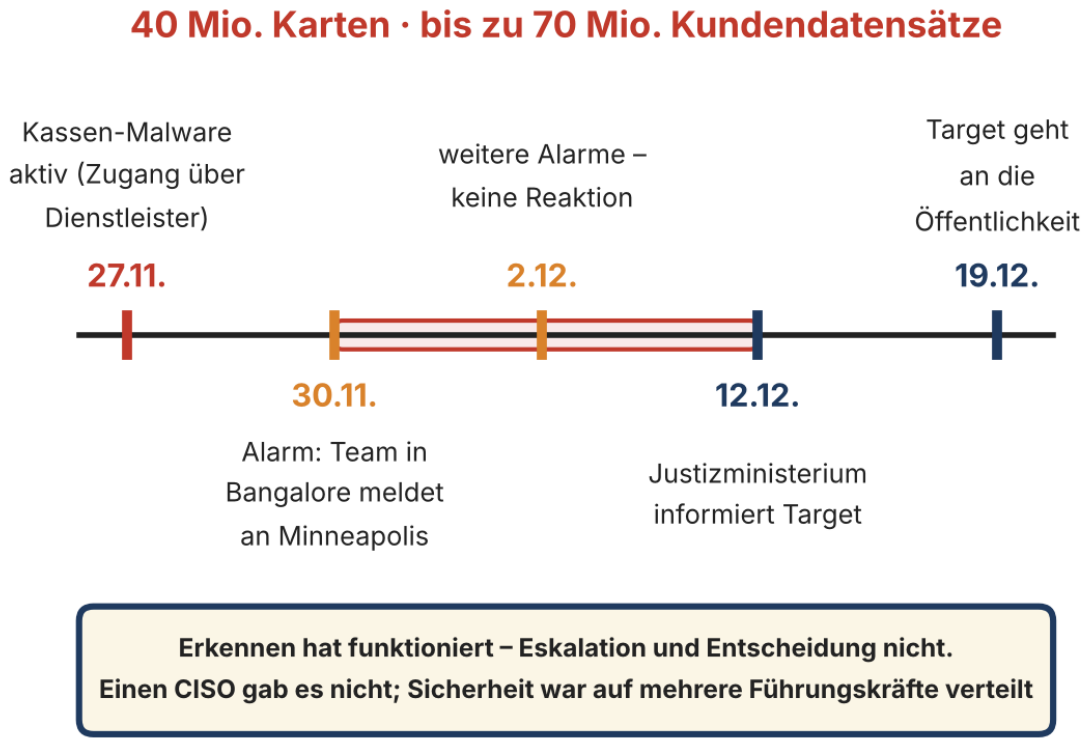
Nach dieser Sitzung können Sie …

– die zentralen Rollen der Cyber-Resilienz unterscheiden: **CISO, SOC, CERT, DPO, BCM, IT Operations, Management**,
– erklären, warum ein CISO ein **Mandat** braucht – und was ohne Mandat oder bei Vertuschung passiert,
– Eskalationswege, **Meldepflichten** und externe Partner (BSI, CERTs, Polizei) einordnen,
– typische **Rollenkonflikte** erkennen und mit einer Governance-Matrix auflösen,
– die Rollen in einer **Übung** auf einen Vorfall anwenden.

Einstieg: Target 2013

- Ab **27. November 2013:** Kassen-Malware in den US-Filialen, Zugang über Zugangsdaten eines Dienstleisters
- **30. November:** Das Überwachungsteam in Bangalore meldet einen Alarm an das SOC in Minneapolis – weitere am **2. Dezember**
- Keine Reaktion; am **12. Dezember** informiert das **US-Justizministerium** Target
- **40 Mio. Kartendaten**, bis zu **70 Mio.** weitere Kundendatensätze

Frage: Die Erkennung hat funktioniert. Woran ist Target gescheitert?



Vom Individuum zur Organisation

Warum Rollen das Rückgrat der Resilienz sind

– Technik kann reagieren – **Menschen entscheiden**.
– Eine Rolle beschreibt **Verantwortung, Befugnis und Schnittstellen**.
– Klare Rollen verhindern Chaos und Doppelarbeit – **Verantwortung ersetzt Schuld**.
– Ohne Struktur keine Geschwindigkeit.

Beispiele: Wer schaltet Systeme ab, wenn Malware erkannt wird? Wer informiert Behörden oder Kunden? Wer genehmigt öffentliche Kommunikation?



Die Rolle des CISO

- Strategische Verantwortung für **Informationssicherheit und Cyber-Resilienz**
- Steuert das **ISMS** (ISO/IEC 27001), koordiniert SOC und CERT
- Übersetzt Risiken in **Entscheidungsvorlagen** für die Geschäftsleitung
- Berichtet idealerweise **direkt an die Geschäftsleitung** – getrennt vom IT-Betrieb

Mandatsdilemma: Verantwortung ohne Befugnis und Ressourcen – *Accountability without Authority*



Fallbeispiel: Uber 2016

- **November 2016:** Angreifer melden dem Sicherheitschef (CSO) einen Datendiebstahl – **57 Mio.** Nutzerdatensätze, **600.000** Führerscheinnummern
- Zahlung von **100.000 USD**, verbucht als **„Bug Bounty“**, gegen Schweigeerklärungen
- Gleichzeitig lief eine **FTC-Untersuchung** zu einem früheren Vorfall – keine Meldung
- **November 2017:** Die neue Unternehmensleitung deckt den Vorfall auf

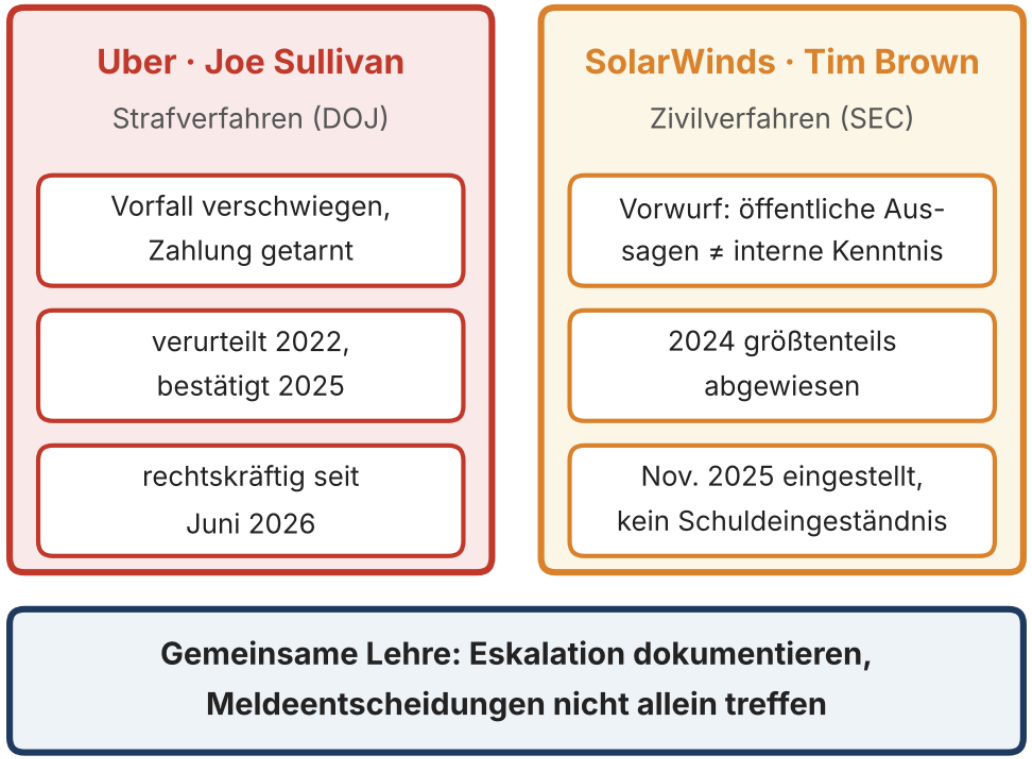
Oktober 2022: Der CSO wird verurteilt – seit Juni 2026 rechtskräftig.



Fallbeispiel: SolarWinds und die SEC

- **Oktober 2023:** Die US-Börsenaufsicht verklagt SolarWinds **und den CISO persönlich** – erstmals einen Sicherheitsverantwortlichen
- Vorwurf: öffentliche Sicherheitsaussagen passten nicht zu **internen Kenntnissen**
- **Juli 2024:** Gericht weist die meisten Vorwürfe ab
- **November 2025:** Verfahren eingestellt – ohne Schuldeingeständnis

Gegenstück zu Uber: kein Vertuschen – aber die Frage, wer was intern wusste und weitergab.

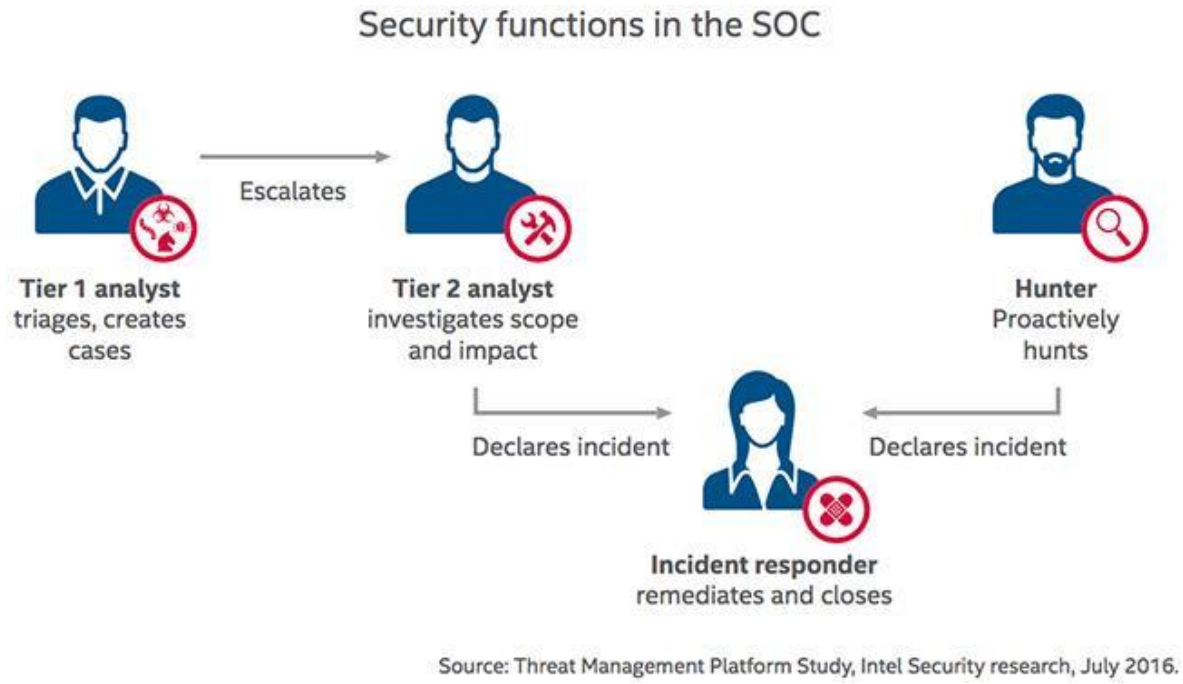


Das Security Operations Center (SOC)

Zentrale Aufgaben

– 24/7-Überwachung von Systemen und Netzwerken
– Erkennung und Analyse von Sicherheitsereignissen (Monitoring & SIEM)
– Eskalation an Incident-Response-Team / CERT
– Dokumentation, Reporting, Threat-Intelligence-Einbindung

Organisation: Schnittstellen zu IT Operations, CISO-Office, Datenschutz, Management



SOC – Tier 1–3

Resilienz entsteht durch Funktionstrennung und Spezialisierung – nicht durch Mehrarbeit.

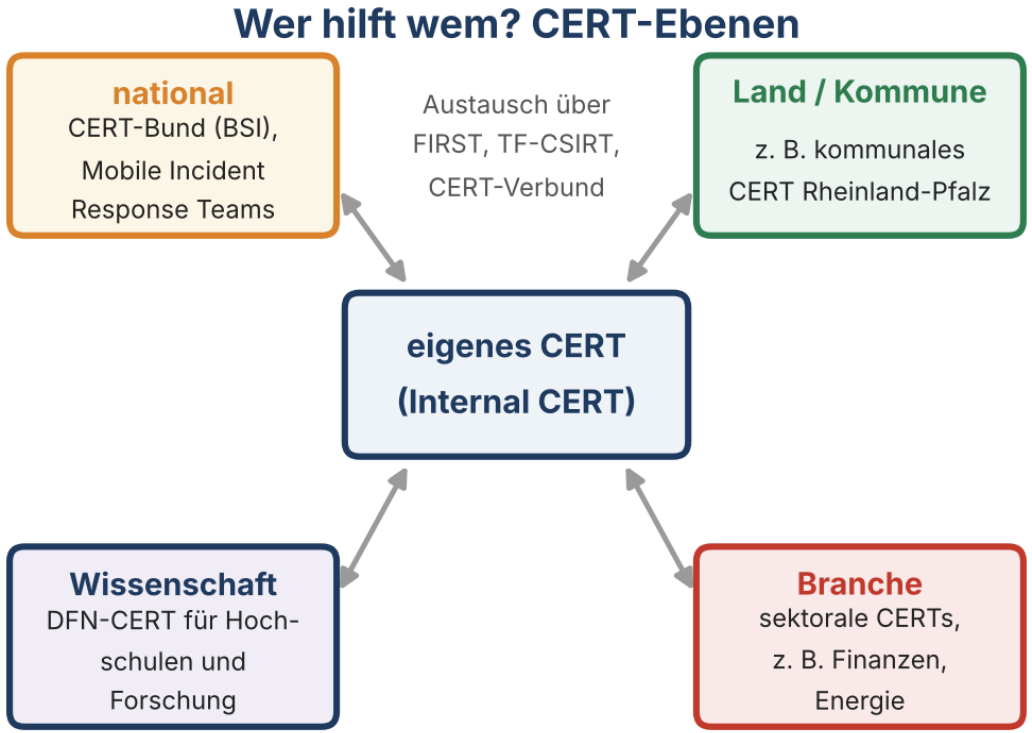
Ebene	Bezeichnung	Aufgabe
Tier 1	Monitoring / Analysis	erste Alarmbewertung, Triage, Eskalation
Tier 2	Investigation	vertiefte Analyse, Kontext, Angriffsketten
Tier 3	Response / Threat Hunting	Eindämmung, Forensik, proaktive Suche

Das Computer Emergency Response Team (CERT)

Mandat: Koordination der technischen Reaktion – Eindämmung, Forensik, Wiederanlauf, Lessons Learned

SOC erkennt, CERT reagiert.

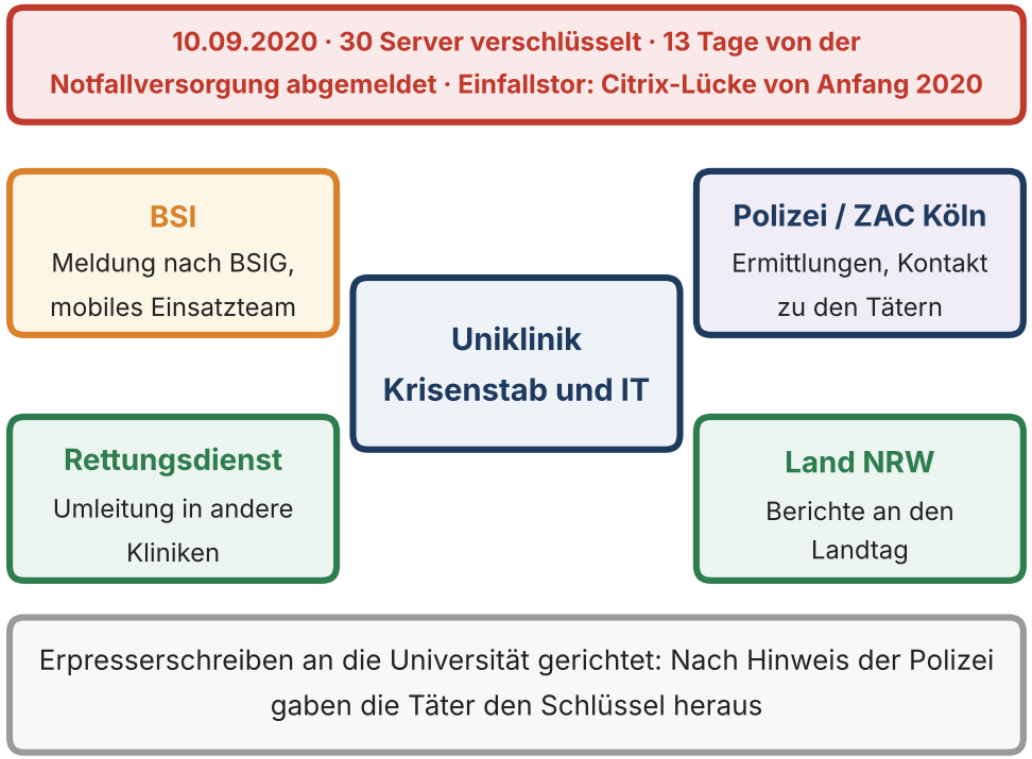
- **Internal CERT:** eigene Organisation oder Konzern
- **National:** CERT-Bund beim BSI, mobile Einsatzteams
- **Land und Kommune:** z. B. kommunales CERT Rheinland-Pfalz
- **Sektoral und akademisch:** Branchen-CERTs, DFN-CERT



Fallbeispiel: Uniklinik Düsseldorf 2020

- **10. September 2020:** Ransomware verschlüsselt **30 Server**; Einfallstor eine seit Januar bekannte **Citrix-Lücke**
- Das Klinikum meldet sich **13 Tage** von der Notfallversorgung ab
- **Meldung an das BSI** nach BSI-Gesetz, BSI unterstützt mit einem **mobilen Einsatzteam**
- Erpresserschreiben an die **Universität** gerichtet – nach Hinweis der **Polizei** geben die Täter den Schlüssel heraus

Viele Rollen kommen von außen – sie müssen vorher bekannt sein.

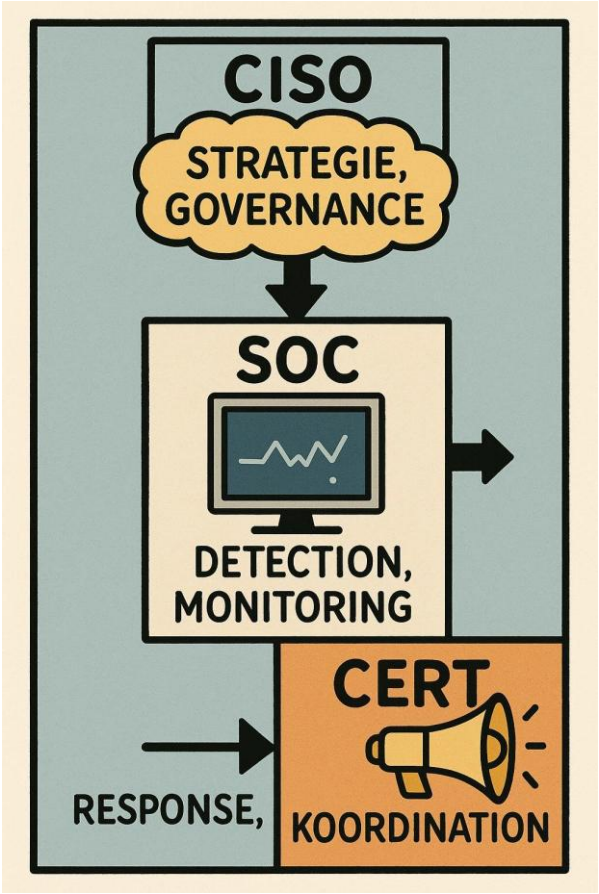


Zusammenspiel von CISO – SOC – CERT

Funktionale Trennung = Resilienz durch Arbeitsteilung

– CISO → Richtlinien, Ressourcen, Reporting (strategisch)
– SOC → Erkennen, Bewerten, Eskalieren (operativ)
– CERT → Koordinieren, Reagieren, Lernen (taktisch)

Zentrale Erfolgsfaktoren: definierte Eskalationsschwellen · gemeinsames Lagebild (Single Source of Truth) · regelmäßige Lage- und Lessons-Learned-Meetings



Weitere Schlüsselrollen in der Cyber-Organisation

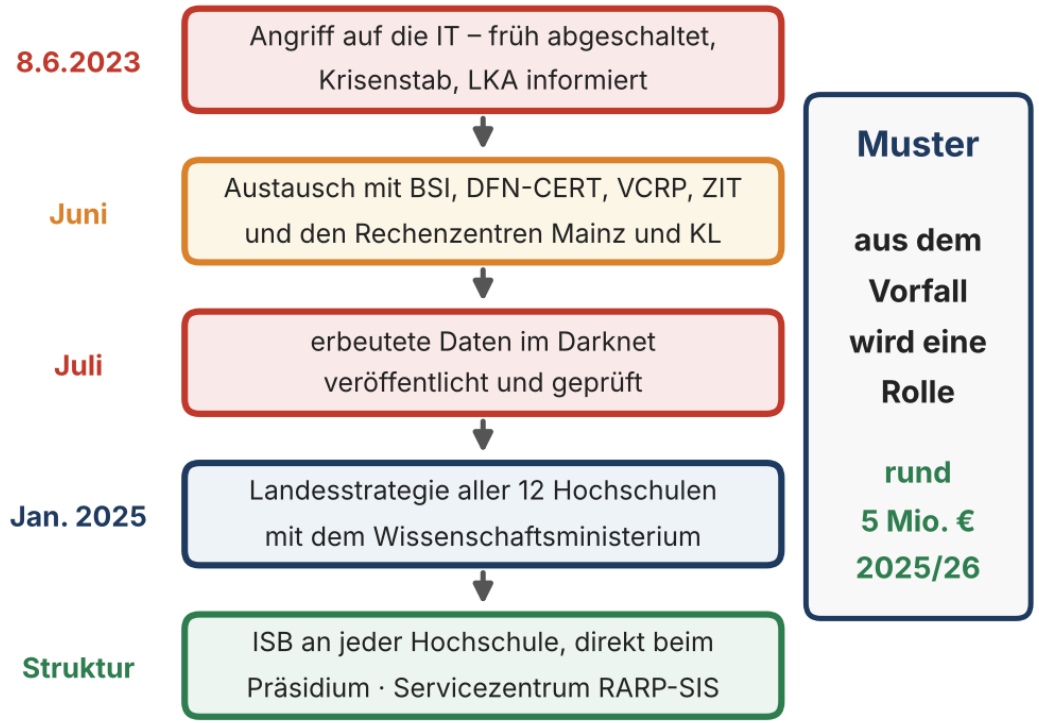
Resilienz ist kein Produkt einzelner Spezialisten, sondern kollektive Verantwortlichkeit.

Rolle	Kernaufgaben	Bezug zur Resilienz
DPO	Datenschutz, Prüfung der DSGVO-Meldung, Schnittstelle zur Aufsicht	schützt Vertrauen & Reputation
BCM Manager	Aufrechterhaltung kritischer Geschäftsprozesse	Recovery & Priorisierung
IT Operations Lead	Betrieb, Infrastruktur, Wiederherstellung	technische Umsetzung
Risk Manager	Risikoanalyse, Bewertung, Register	Früherkennung & Priorisierung
Management Board	Governance, Ressourcen, Risikoakzeptanz	strategische Steuerung

Fallbeispiel: Hochschule Kaiserslautern 2023

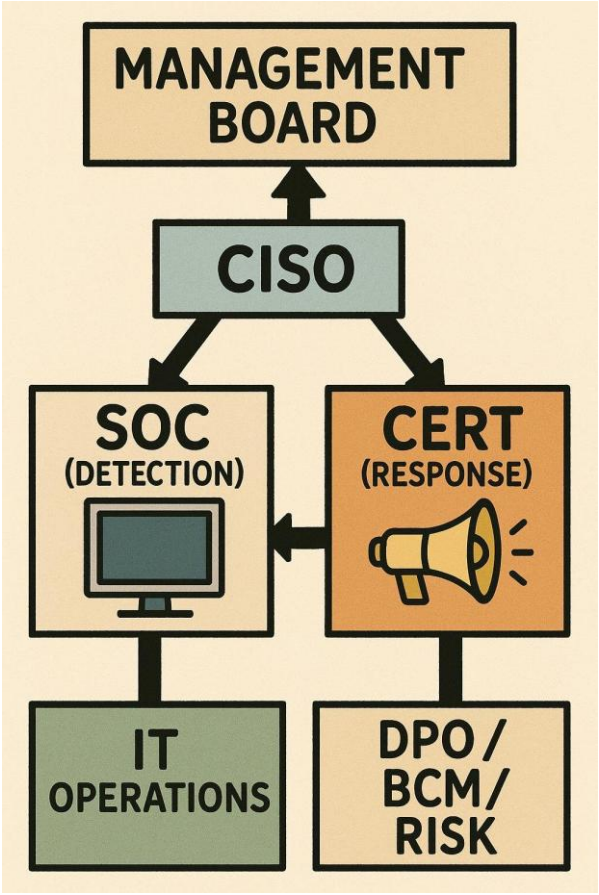
- **8. Juni 2023:** Angriff auf die gesamte IT – die Hochschule **schaltet früh ab**, bildet einen **Krisenstab** und informiert das LKA
- Austausch mit **BSI, DFN-CERT**, VCRP, ZIT und den Rechenzentren in Mainz und Kaiserslautern
- Juli: erbeutete Daten im Darknet veröffentlicht
- **Januar 2025:** Landesstrategie aller **12 Hochschulen** mit dem Wissenschaftsministerium – **Informationssicherheitsbeauftragte** an jeder Hochschule, direkt beim Präsidium

Aus dem Vorfall wird eine Rolle.



Kommunikations- und Eskalationsmodell

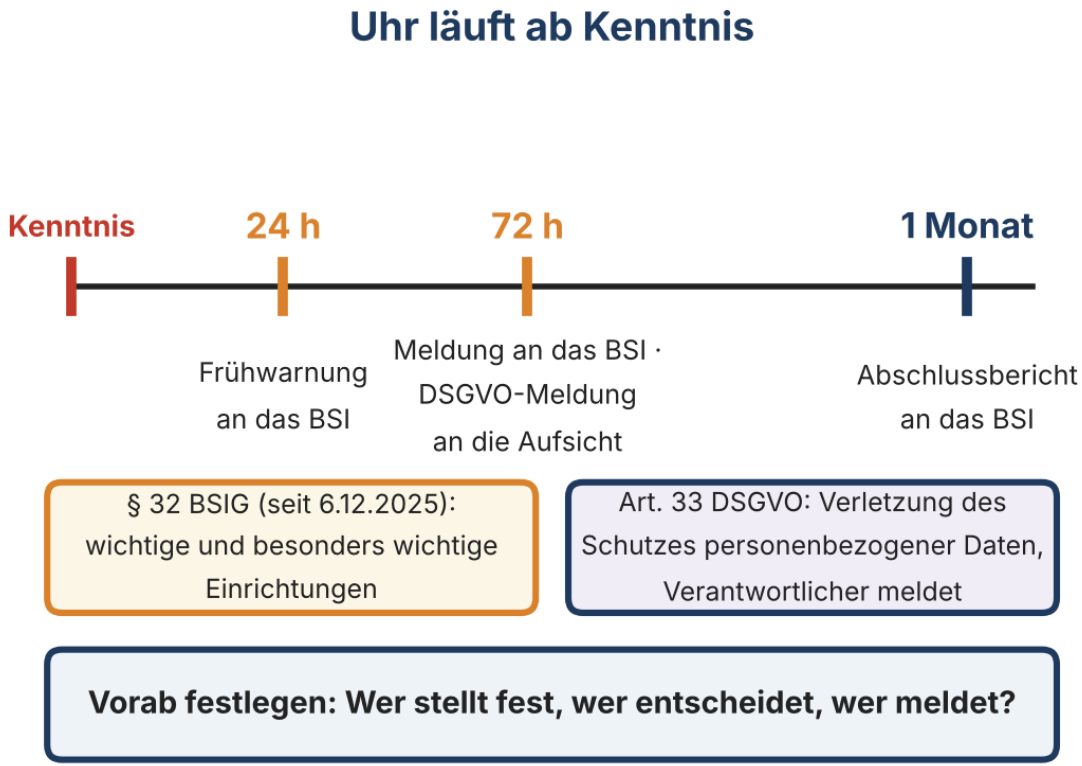
- **Single Source of Truth:** ein gemeinsames Lagebild
- **Time to Inform:** Informationspflicht in definierten Fristen
- **Bidirektionalität:** Rückmeldungen fließen ins Lagebild
- **Vorab definierte Kanäle** (z. B. Teams-Crisis-Channel) und **Offline-Fallback**
- **Eskalationsschwellen** schriftlich: ab wann CISO, ab wann Geschäftsleitung



Meldepflichten

- **§ 32 BSIG** (seit 6.12.2025): erhebliche Sicherheitsvorfälle – Frühwarnung **24 h**, Meldung **72 h**, Abschlussbericht nach **einem Monat**
- **Art. 33 DSGVO:** Datenschutzverletzung binnen **72 h** an die Aufsichtsbehörde
- **Technischer Vorfall ohne Meldepflicht:** trotzdem dokumentieren
- **Betriebsunterbrechung:** BCM-relevant, Eskalation nach BIA

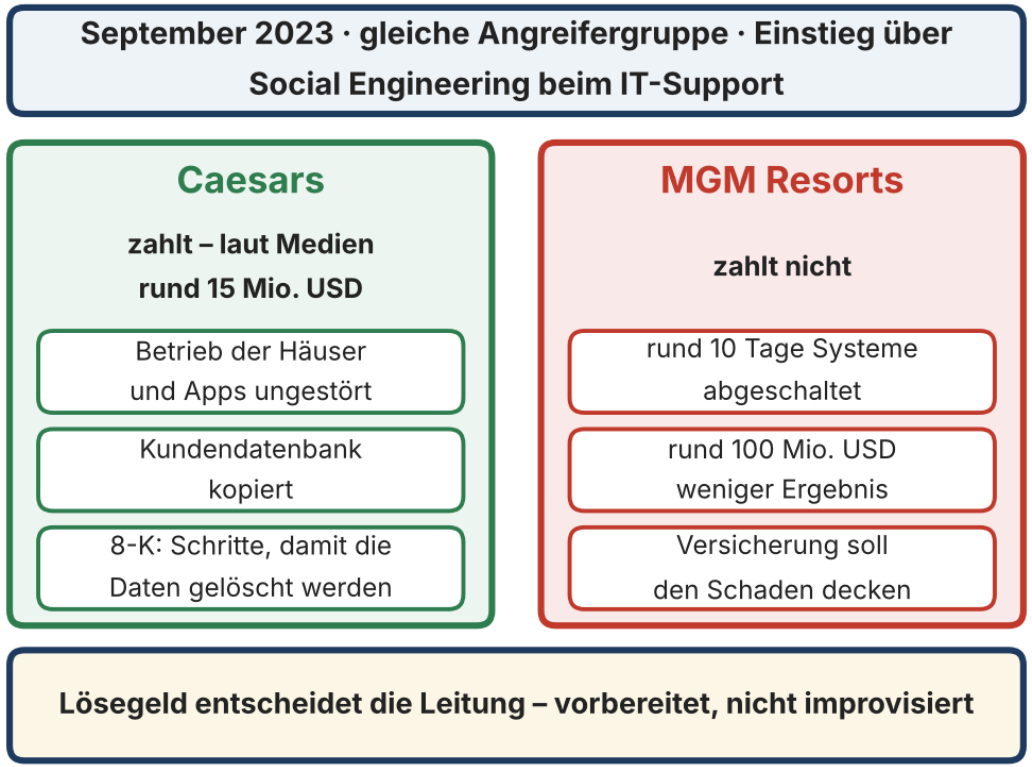
Nicht jeder Incident ist meldepflichtig – aber jeder muss dokumentiert werden.



Fallbeispiel: MGM und Caesars 2023

- **September 2023:** dieselbe Angreifergruppe trifft zwei Casino-Konzerne in Las Vegas – Einstieg über **Social Engineering beim IT-Support**
- **Caesars:** Kundendatenbank kopiert, Betrieb ungestört; laut Medien rund **15 Mio. USD** gezahlt, damit die Daten gelöscht werden
- **MGM:** zahlt nicht, schaltet Systeme ab – rund **10 Tage** Störung, rund **100 Mio. USD** weniger Ergebnis

Zahlen oder nicht ist keine Technikfrage, sondern eine Entscheidung der Leitung.



Kooperation und Grenzen der Rollen

Typische Konfliktlinien und Lösungsprinzipien:

Konflikt	Ursache	Resiliente Lösung
CISO vs. CIO	Security vs. Verfügbarkeit	klare Zieltrennung, gemeinsame KPIs
SOC vs. IT Ops	„Wer darf eingreifen?“	Runbooks & Eskalationskriterien
CERT vs. PR	Kommunikationsfreigabe	vorab definierte Kommunikationsmatrix
BCM vs. Security	Prioritätenunterschiede	Business-Impact-Analysen abstimmen
DPO vs. Incident Team	Datenschutzmeldungen	Abstimmung mit Legal-Team & CISO

Governance-Matrix (Beispiel)

Verantwortung ersetzt Diskussion.

Entscheidungsfeld	Primär	Stellvertretend	Information
Isolierung eines Systems	CERT	IT Ops	CISO
Externe Kommunikation	Management	PR	CISO, DPO
Behördenmeldung	DPO / CISO	CISO / DPO	Management
Lösegeldfrage	Management	–	CISO, Legal
Wiederanlaufentscheidung	BCM	CERT	Management
Lessons Learned	CISO	CERT	alle Bereiche

Best Practices & Standards

Rahmenwerke und Leitlinien für Rollenmodelle in der Cyber-Organisation:

Standard / Leitlinie	Relevanz
ISO/IEC 27001	Rollen und Verantwortlichkeiten im ISMS
ISO/IEC 27035	Incident-Management-Prozess und Eskalationspfade
ISO 22320	Krisenmanagement und Führungsstrukturen in Notlagen
ISO 22316	Grundprinzipien organisationaler Resilienz
BSI-Standard 200-4	Business Continuity Management
NIS-2-Richtlinie (EU) 2022/2555	Verantwortung der Leitung, Meldepflichten
BSIG (Fassung NIS2UmsuCG)	§ 32 Meldepflichten, § 38 Pflichten der Geschäftsleitung

Übung: Wer macht was im Incident?

Szenario: Phishing führt zu kompromittierten Admin-Zugangsdaten; das SOC sieht verdächtige Logins. Gruppen zu 4–5 Personen, 20 Minuten.

1. Wer wird zuerst informiert?
2. Wer entscheidet über die Systemtrennung?
3. Wer kommuniziert intern / extern?
4. Wer bewertet rechtliche Meldepflichten – und wer zählt die Stunden?
5. Wer dokumentiert und berichtet an das Management?

Ziel: Rollen abgrenzen → Kollisionspunkte erkennen → gemeinsame Eskalationslogik entwickeln.

Was die Fälle zeigen

Fall	Rolle	Lehre
Target 2013	SOC → Entscheidung	Ein Alarm braucht einen Eigentümer und eine Eskalationsschwelle
Uber 2016	CISO	Meldeentscheidungen gehören nicht in eine Hand
SolarWinds 2023–2025	CISO	Eskalation dokumentieren, außen sagen, was innen gilt
Uniklinik Düsseldorf 2020	CERT, externe Partner	BSI, Polizei, Leitstelle – vorher bekannt
HS Kaiserslautern 2023	Rollenaufbau	Aus dem Vorfall wird eine Rolle (ISB beim Präsidium)
MGM / Caesars 2023	Management Board	Lösegeld ist Leitungsentscheidung – vorbereitet

Kernpunkte

- Rollen sind das **organisatorische Immunsystem** – Erkennen allein reicht nicht (Target).
- Der CISO braucht ein **Mandat und einen Berichtsweg**; Vertuschen endet persönlich (Uber, SolarWinds).
- **SOC erkennt, CERT reagiert** – mit externen Partnern, die vorher bekannt sind (Uniklinik Düsseldorf).
- Rollen entstehen oft erst nach dem Vorfall – **besser vorher** (Hochschule Kaiserslautern).
- Meldepflichten laufen ab Kenntnis; **Leitungsentscheidungen** gehören vorbereitet (MGM, Caesars).

Ausblick & Hausaufgabe

Nächste Sitzung: Technische Resilienz I – Backup, Disaster Recovery, Notfalltests
Hausaufgabe: Ergänzen Sie Ihre Rollenkarte aus Sitzung 5 um zwei Zeilen: **Wer darf einen Restore aus dem Backup freigeben** – und **wann wurde zuletzt ein Restore getestet**? Finden Sie für Ihre Organisation heraus, ob es darauf eine Antwort gibt.
Kapitel zum Termin · Skript · Glossar · Quellen